

Unauthenticated Credential Registration Enables Account Takeover

COMPONENT	CGS Associate Authentication API — <code>POST /api/associate (transaction: "register")</code>
SEVERITY	Critical — CVSS 3.1 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H); 10.0 if a compromised associate identity grants access to other platform applications (scope change)
STATUS	Confirmed against [uat.teamcgs.io / production] on [date]
REPORTED BY	[name / team]
DATE	2026-08-06

Summary

The credential-registration endpoint requires no caller authentication and accepts the associate's **employee ID as the sole proof of identity**. Employee IDs are identifiers, not secrets — they appear on badges, in email signatures, and throughout HR records. Any party who knows (or guesses) a domain ID and its matching employee ID can set that associate's password and sign in as them. No API key, no session, and no interaction from the victim is required.

This is documented in the API's own reference, which states of this route: *"Currently unauthenticated. This route does not enforce x-api-key or a session."*

Affected endpoint

```
POST /api/associate
{ "transaction": "register", "domainId": "...", "employeeId": "...",
  "password": "...", "confirmPassword": "..."} }
```

- No x-api-key required.
- No session required.

- Success sets the password and sends a welcome email; response is { "success": true }.
 - Failure only distinguishes "Invalid Domain ID" from "Invalid Employee ID."
-

Root cause

Two independent defects combine:

1. **No caller authentication.** Unlike POST /api/login, which is gated by x-api-key and restricted to server-to-server callers, the register route is reachable by anyone.
2. **An identifier is treated as a credential.** The employee ID is the only thing standing between a request and a new password, but it is not secret and, at seven digits, is low-entropy.

The route also has **no documented rate limit** (unlike verifyDomain at 60/min and login at 10/min), so the employee-ID space is open to brute force even when the value isn't already known.

Impact

An attacker can take full control of any associate account:

- **Confidentiality** — sign in as the victim and read everything they can see, including the full PII returned by GET /api/associate.
- **Integrity** — act as the victim in any application that trusts this identity.
- **Availability** — the victim's real password is overwritten; they are locked out until a reset.

Because the associate identity is shared across the CGS One platform, a single takeover may pivot into every application that relies on it.

Attack scenarios

1. **Targeted.** Attacker knows a colleague's domain ID and employee ID (both routinely visible). One request registers a password of the attacker's choosing.

2. **Unregistered-account harvest.** The anonymous POST /api/verifyDomain returns both exists and registered. An attacker enumerates valid domain IDs and filters for registered: false — accounts with **no password yet**, which are the ideal targets: nothing is overwritten and the legitimate user never notices a changed credential. This endpoint directly amplifies the finding.
3. **Brute force.** With no rate limit on the register route, a known domain ID plus a seven-digit employee-ID search space is enumerable.

Reproduction (non-destructive)

Confirmed without touching any third-party account:

a. The gate is absent. An anonymous request with a format-valid but non-existent domain ID reaches business logic and returns 400 Invalid Domain ID rather than 401 Unauthorized — proving no authentication is enforced before the endpoint acts.

```
$ curl -sS -X POST https://[host]/api/associate \  
  -H 'content-type: application/json' \  
  -d \  
  '{"transaction":"register","domainId":"ZZ00000","employeeId":"0000000","password":"x","confirmPassword":"x"}' \  
[paste actual response + HTTP status]
```

b. End-to-end on the reporter's own, consented account. verifyDomain reported registered: false; an anonymous register call (no x-api-key) then flipped it to registered: true:

```
[paste the two verifyDomain responses showing the false -> true flip]
```

No account other than the reporter's own was modified.

Remediation

IMMEDIATE (STOPS ANONYMOUS ACCESS)

- Require `x-api-key` on the register route, matching `POST /api/login`. Restrict to server-to-server callers (no CORS).
- Add a rate limit consistent with the other authentication endpoints.

PROPER (REMOVES IDENTIFIER-AS-CREDENTIAL)

- Stop accepting the employee ID as proof of identity. Require a **possession factor**: email a one-time code to the corporate address already stored on the associate record and require it before a password can be set. The record holds the address, so no new data source is needed.

HARDENING (CLOSES THE AMPLIFIERS)

- Gate `POST /api/verifyDomain` behind `x-api-key` so account existence and registration state are no longer anonymously enumerable (see related finding below).
- Validate `confirmPassword` server-side; today it is documented as ignored.
- Move registration to its own path (e.g. `/api/associate/register`) so the authentication posture is readable per-URL. Currently `GET /api/associate` requires auth while `POST` to the same path requires none.

Related findings that compound this one

- **Anonymous enumeration oracle** (`verifyDomain`): amplifies scenario 2 and undercuts the careful anti-enumeration design in `/api/login`.
- **`confirmPassword` not validated**: a client-side mismatch check the server silently ignores.
- **Split security model on one path**: `GET/POST /api/associate` enforce different auth, which invites a gateway or review to secure the wrong one.

References

- CGS Associate Authentication API reference, `POST /api/associate` — access note: *"Currently unauthenticated... if you expose it externally, add caller authentication."*

- OWASP API Security Top 10: **API2:2023 Broken Authentication, API5:2023 Broken Function Level Authorization.**